# AVERIX TECHNOLOGIES PVT. LTD.

## INTEGRATED INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

ISO/IEC 27001:2022 + NIST CYBERSECURITY FRAMEWORK (CSF)

**Prepared By:**

Averix Security Assessment Team

**Date:** November 2026

**Document Version:** 1.0

**Confidentiality:** Portfolio Project – Fictional Company

# Executive Summary

Averix Technologies Pvt. Ltd. is a fictitious Information Technology (IT) firm located in India; it has around 50 employees. Averix develops and offers a Software as a Service (SaaS)-based Human Resource Management System (HRMS) for Small to Medium-Sized Businesses (SMBs).

As such, the HRMS platform used by Averix Technologies stores sensitive information about the company's employees such as their personal information, attendance, payroll, information related to recruitment of employees and information related to user accounts created on the platform. Maintaining confidentiality, integrity and availability of such information is crucial for the company's operations and for maintaining its customers' trust.

This project is to establish an Integrated Information Security Management System (ISMS) for Averix Technologies Pvt. Ltd. according to ISO/IEC 27001:2022 and with support of the NIST Cybersecurity Framework (CSF) 2.0.

ISO/IEC 27001:2022 shall contain the requirements for establishing, implementing, maintaining and improving an Information Security Management System (ISMS) within the organization. The NIST CSF 2.0 shall contain the requirements for evaluating the organization's cybersecurity practices within six functions: Govern, Identify, Protect, Detect, Respond and Recover.

The project shall provide understanding of business environment, identification of interested parties, defining the scope of the ISMS, assessing information security risks, selecting appropriate security controls and assessing Averix's current cybersecurity practices.

The existing cybersecurity risk assessment for Averix Technologies will be used as the basis for identifying and addressing information security risks within the ISMS.

***Note:*** *This is a fictional portfolio implementation exercise based on defined project assumptions. It does not represent an actual organizational implementation, independent audit or ISO certification.*

# Business Context

Averix Technologies Pvt. Ltd. is a fictional Information Technology company based in India with approximately 50 employees. The organization develops and provides a Software as a Service (SaaS)-based Human Resource Management System (HRMS) for small and medium-sized businesses.

The HRMS platform of Averix Technologies Pvt. Ltd. enables employees of other organizations to manage employee information, record attendance, manage leaves, calculate payroll, manage recruitment and manage user accounts.

The HRMS application, employee database, payroll module, user accounts, backup systems, source code repository and company email system are some of the key assets of the organization that support its daily operations.

As the company processes and stores sensitive information of its employees as well as of its customers, maintaining information security of highest standards is critical to the business.

## 3.2 Internal Issues

Internal issues are factors within the organization that may affect its ability to achieve its information security objectives.

The following potential internal issues have been identified for Averix Technologies:

| Internal Issue | Potential Impact |
|---|---|
| Weak access management practices | Unauthorized access to sensitive information |
| Insufficient employee security awareness | Increased risk of phishing and social engineering attacks |
| Inadequate backup procedures | Potential data loss and recovery difficulties |
| Delayed software updates | Increased exposure to software vulnerabilities |
| Insufficient security monitoring | Delayed detection of suspicious activities |
| Limited formal security procedures | Inconsistent information security practices |

## 3.3 External Issues

External issues are factors outside the organization that may influence its information security management system.

The following potential external issues have been identified:

| External Issue | Potential Impact |
|---|---|
| Increasing Cybersecurity threats | Greater exposure to ransomware, phishing and other cyberattacks |
| Data protection and privacy requirements | Legal and regulatory compliance risks |
| Third-party service provider dependencies | Potential service disruption or security incidents |
| Changing technology and security threats | Need for continuous security improvements |
| Customer security expectations | Contractual and reputational risks |
| Cloud service disruptions | Reduced availability of the HRMS platform |

## 3.4 Summary

This organizational context analysis identifies several internal and external factors that have a direct bearing on the information security of Averix Technologies Pvt. Ltd.

The above-mentioned internal and external issues shall be considered while defining information security objectives, while conducting the risk assessment and while identifying and implementing appropriate security controls.

The organization must periodically review the internal and external issues to verify that the ISMS is relevant to the business environment.

***Note:*** *The internal and external issues mentioned above are assumed for the purpose of this fictional portfolio exercise. They have not been verified through an actual organizational assessment.*

# Interested Parties and their Requirements

## 4.1 Identification of Interested Parties

Averix Technologies Pvt. Ltd. interacts with a number of interested parties, both internal and external, which have requirements for information security.

The organization's Information Security Management System (ISMS) is influenced by the expectations, contractual obligations, operational responsibilities and legal requirements of its various interested parties.

It is important for the organization to identify its various interested parties and understand the information security requirements that are relevant to its ISMS in order to establish and maintain an effective ISMS.

## 4.2 Internal Interested Parties

| Interested Party | Information Security Requirements |
|---|---|
| Management | Effective information security risk management, policy oversight and compliance monitoring. |
| Employees | Protection of personal information, secure access to systems and clear security responsibilities. |
| IT and Security Team | Appropriate security tools, access management, monitoring and incident management procedures. |

## 4.3 External Interested Parties

| Interested Party | Information Security Requirements |
|---|---|
| Customers | Confidentiality and protection of employee information, reliable HRMS services and appropriate access controls. |
| Regulatory Authorities | Compliance with applicable legal and regulatory requirements relating to information security and data protection. |
| Cloud Service Providers | Defined security responsibilities, secure service delivery and appropriate protection of hosted information. |
| Business Partners | Secure information sharing and protection of information exchanged with Averix. |

## 4.4 Relevant Requirements of Interested Parties

Averix Technologies must determine which requirements of its interested parties are relevant to the ISMS.

These requirements may include:

1. Protection of customer and employee personal information.
2. Appropriate user access controls and authentication mechanisms.
3. Availability and reliability of the HRMS platform.
4. 4.Secure storage and handling of sensitive information.
5. Compliance with applicable legal, regulatory and contractual obligations.
6. Appropriate incident reporting and response arrangements.
7. Protection of information shared with third-party service providers.

Review of these requirements should take place on a regular basis and as a result of any significant changes to Averix Technologies' business or stakeholders.

***Note:*** *The above list of interested parties and their requirements are proposed for this fictional portfolio exercise only. The organization must verify the actual contractual, legal and regulatory requirements of each interested party.*

# ISMS SCOPE

## 5.1 Purpose of the ISMS Scope

The purpose of defining the ISMS scope is to establish the boundaries and applicability of the Information Security Management System (ISMS) within Averix Technologies Pvt. Ltd.

The scope takes into account Averix's business activities, technology, information and operation to ensure that all relevant information security risks are managed.

## 5.2 Systems and Activities Included in the ISMS

The following systems and activities are included within the ISMS scope:

The scope of the ISMS includes the people, processes and technology involved in the development, maintenance and operation of the HRMS platform as well as the information and assets being protected.

## 5.3 Organizational and Information Boundaries

The ISMS applies to the business activities of Averix Technologies involved in the development, operation, maintenance and support of the SaaS-based HRMS platform.

The scope of the ISMS covers the information processed, stored and transmitted by the systems in scope. This includes the customer's information, employee records, payroll information and application source code.

All employees and personnel related to Averix Technologies involved in the above activities must adhere to the Information Security Policies and Procedures.

## 5.4 Areas Outside the ISMS Scope

The following areas are excluded from the defined ISMS scope:

1. Customers' computers and networks which are outside Averix's administrative control.
2. Independent security operations of third-party service providers, except for services and interfaces relevant to Averix's information security responsibilities.
3. 3. Activities and systems not related to the development, operation and support of the HRMS platform.

These are not excluded from Averix's responsibility to manage information security risks related to relevant third-party services and relationships.

## 5.5 ISMS Scope Statement

The Information Security Management System of Averix Technologies Pvt. Ltd. applies to the development, operation, maintenance and support of the SaaS-based Human Resource Management System (HRMS) including the HRMS application, employee database, payroll module, user accounts, backup systems, source code repository and company email system.

The scope of the ISMS includes all people, processes, information assets and supporting technology used to deliver and maintain the HRMS platform and to protect organizational and customer information with respect to confidentiality, integrity and availability.

This scope statement has been defined for the purpose of the fictional portfolio implementation exercise and is subject to management review and approval.

# Establishment of ISMS

## 6.1 Establishment of the ISMS

Averix Technologies Pvt. Ltd. will establish an Information Security Management System (ISMS) to manage the information security risks of the company's SaaS-based Human Resource Management System (HRMS).

The ISMS will be used to protect both the organization and customer's information by defining the organization's security policies, procedures, responsibilities and implementing the required security controls.

The organization's ISMS will be established based on the requirements of ISO/IEC 27001:2022 and will be further strengthened by the NIST Cybersecurity Framework (CSF) 2.0 to manage cybersecurity risks within the organization.

## 6.2 Implementation of the ISMS

The organization will implement the ISMS through the following activities:

1. Establish information security policies and procedures.
2. Identify information assets and associated security risks.
3. Develop a risk treatment plan to address identified risks.
4. Select and implement appropriate information security controls.
5. Define security responsibilities for employees and relevant personnel.
6. Establish processes for monitoring and managing information security incidents.
7. Conduct periodic reviews to evaluate the effectiveness of the ISMS.

## 6.3 Maintenance and Continual Improvement

The organization shall continuously monitor and improve the ISMS through management reviews, internal audits and corrective actions.

The organization will continuously review its information security risks, the effectiveness of the security controls in place and fix any issues found.

Changes in the business operations, technology, threats and requirements will be included in the update of the Information Security Management System.

These activities shall ensure that the Information Security Management System is maintained effectively and in line with the business objectives.

# Leadership and Information Security Policy

## 7.1 Leadership and Commitment

The top management of Averix Technologies Pvt. Ltd. will provide the leadership and commitment for the development and operation of the Information Security Management System (ISMS).

The organization’s information security objectives must be linked to its business objectives, and sufficient resources must be made available for the implementation and maintenance of the ISMS.

Management responsibilities include:

1. Establishing and supporting the organization's information security policies.
2. Ensuring that information security requirements are integrated into business processes.
3. Providing adequate resources for information security activities.
4. Assigning and communicating information security responsibilities.
5. Promoting awareness of information security among employees.
6. Reviewing ISMS performance and supporting continual improvement.
7. Ensuring that identified information security risks are appropriately addressed.

## 7.2 Information Security Policy

Averix Technologies Pvt. Ltd. will establish an Information Security Policy to provide direction and guidance for protecting organizational and customer information.

The Information Security Policy applies to all employees and relevant personnel who access, process, store or manage company information and systems.

The organization's information security policy will be based on the following principles:

1. **Confidentiality:** Protect customer and employee sensitive information from unauthorized access and disclosure.

2. **Integrity**: Maintain the accuracy and completeness of business information and prevent unauthorized modifications.

3. **Availability:** Ensure that information and business systems remain accessible to authorized users when required.

4. **Access Management**: Provide access to information and systems based on job responsibilities and business requirements.

5. **Risk Management**: Identify, assess and address information security risks through appropriate security controls.

6. **Incident Management:** Establish procedures for reporting, managing and responding to information security incidents.

7. **Legal and Regulatory Compliance**: Identify and comply with applicable legal, regulatory and contractual information security requirements.

## 7.3 Communication and Review of the Policy

The Information Security Policy will be communicated to employees and other relevant interested parties.

Employees will understand the need for protecting company information as well as the need for following security procedures.

The policy will be reviewed on a regular basis, and also in case of significant changes to business, technology, information security risks or applicable requirements.

***Note:*** *The leadership commitments and policy described above represent proposed arrangements for this fictional portfolio exercise. They require formal management approval before being treated as approved organizational policies.*

# Organizational Roles, Responsibilities and Authorities

## 8.1 Assignment of Information Security Responsibilities

The responsibilities and authorities for information security within Averix Technologies Pvt. Ltd. will be assigned to appropriate personnel within the organization to ensure that the Information Security Management System (ISMS) is being implemented and maintained effectively.

Top management will ensure that responsibilities and authorities related to information security are clearly defined, assigned and communicated within the organization.

The following roles and responsibilities are proposed for Averix Technologies Pvt. Ltd.

## 8.2 Roles and Responsibilities

| Role | Responsibilities |
|---|---|
| Top Management | Approve information security policies, provide resources, oversee ISMS performance and support continual improvement. |
| GRC Analyst | Coordinate risk assessments, maintain risk registers, monitor compliance requirements and support internal audits. |
| IT Manager | Oversee IT security operations, access management, system maintenance and implementation of security controls. |
| System Administrator | Manage user accounts, configure access permissions, maintain systems and monitor system activities. |
| HR Manager | Protect employee information, manage HR records securely and ensure appropriate access to HR data. |
| Employees | Follow information security policies, protect company information and report suspected security incidents. |

## 8.3 Communication of Responsibilities

Responsibilities for information security will be communicated to the employees and other relevant persons by means of the organizational policies, procedures, the role descriptions and the security awareness activities.

Personnel are made aware of their responsibilities to protect the information assets of Averix Technologies Pvt. Ltd. and adhere to the information security requirements that have been established.

## 8.4 Reporting and Accountability

All employees must report any suspected information security incidents, unauthorized access to information or data, or any suspected data breaches through the organization's designated reporting process.

Management shall be responsible for ensuring that assigned responsibilities are being implemented as described and that information security roles and responsibilities remain appropriate.

Any changes to the organization, business or information security requirements will be taken into account when updating assigned responsibilities.

***Note:*** *The above proposed roles and responsibilities for this fictional portfolio exercise have not been assigned to or approved by Averix Technologies Pvt. Ltd.*

# Information Security and Risk Assessment Methodology

## 9.1 Introduction

Information security risk assessment is the process of identifying and analyzing the information security risks that an organization's information assets, systems and processes may face, in order to assess the impact of such risks on the organization's objectives and to decide on appropriate measures to manage such risks.

Averix Technologies Pvt. Ltd. will use a risk-based approach to identify potential threats and vulnerabilities affecting its SaaS-based Human Resource Management System (HRMS) and supporting systems.

The likelihood of a security incident occurring and the potential impact that such an incident may have on the confidentiality, integrity and availability of organizational information will be considered.

## 9.2 Risk Identification

Risk Identification is the process of identifying possible threats and vulnerabilities to an organization's information assets.

For Averix Technologies, the risk identification process will consider:

1. Identification of important information assets.
2. Identification of potential cybersecurity threats.
3. Identification of vulnerabilities associated with each asset.
4. Identification of potential consequences to business operations.

The existing cybersecurity risk assessment identified threats such as phishing attacks, malware, unauthorized access, data manipulation, service disruption, data loss and source code compromise.

## 9.3 Risk Analysis Methodology

Each identified risk will be analysed using two factors:

1. **Likelihood:** The possibility of a threat exploiting an existing vulnerability and causing a security incident.

2. **Impact**: The potential consequences of a security incident on the organization's information, systems and business operations.

The risk score will be calculated using the following formula:

**Risk Score = Likelihood × Impact**

Both likelihood and impact will be rated on a scale of 1 to 5.

## 9.4 Likelihood and Impact Scales

| Score | Likelihood | Impact |
|---|---|---|
| 1 | Rare | Insignificant |
| 2 | Unlikely | Minor |
| 3 | Possible | Moderate |
| 4 | Likely | Major |
| 5 | Almost Certain | Severe |

## 9.5 Risk Rating Classification

| Risk Score | Risk Level |
|---|---|
| 1-4 | Low |
| 5-9 | Medium |
| 10-16 | High |
| 17-25 | Critical |

The calculated risk scores will be classified into four levels to determine the priority of each identified risk.

## 9.6 Risk Evaluation

The risk assessment results will be evaluated against the risk acceptance criteria of Averix Technologies.

Risks with a higher rating will receive more attention and priority when defining measures to treat the risks.

The results of the risk assessment will be recorded in a risk register containing all identified risks, their respective ratings and the measures to treat the risks.

The risk assessment will be updated on a regular basis to reflect changes in business operations, technologies, vulnerabilities and threats.

# Information Security Risk Treatment Plan

## 10.1 Introduction

The Information Security Risk Treatment Plan shall describe the measures that shall be implemented in order to treat the identified risks to the information assets of Averix Technologies Pvt. Ltd. in order to decrease their potential impact on the organization's information assets and business processes.

Averix Technologies Pvt. Ltd. will develop a risk treatment plan based on the results of its information security risk assessment.

In general the organization will apply risk modification to reduce the likelihood and impact of identified cybersecurity threats by implementing appropriate security measures.

## 10.2 Risk Treatment Options

The organization will consider the following risk treatment options:

1. **Risk Modification –** Implement security controls to reduce the likelihood or impact of identified risks.
2. **Risk Avoidance –** Discontinue activities that create unacceptable information security risks.
3. **Risk Sharing –** Share certain risks with third parties through appropriate agreements or other arrangements.
4. **Risk Retention –** Accept risks that fall within the organization's established risk acceptance criteria.

## 10.3 Recommended Risk Treatment Measures

The table below lists the measures that Averix Technologies Pvt. Ltd. will implement for the seven risks identified in the existing cybersecurity risk assessment.

| Risk ID | Identified Risk | Recommended Security Measures |
|---|---|---|
| R01 | Unauthorized access to employee data | Implement role-based access control (RBAC) and conduct regular access permission reviews. |
| R02 | Phishing attacks | Conduct employee security awareness training and enable multi-factor authentication |

| | | |
|---|---|---|
| R03 | Payroll data manipulation | Restrict payroll permissions and maintain records of changes to payroll information. |
| R04 | Malware or ransomware | Apply software updates regularly and implement appropriate malware protection. |
| R05 | Data Loss | Maintain regular backups and periodically test data restoration. |
| RO6 | Source code Compromise | Restrict source code repository access and review code changes. |
| RO7 | Email Account Compromise | Enforce strong password practices and enable multi-factor authentication. |

## 10.4 Risk Treatment Plan

The proposed treatment measures will be documented in a Risk Treatment Plan and tracked until implemented.

For each security measure, the name of the person responsible for the implementation of the security measure shall be mentioned.

The effectiveness of implemented controls will be reviewed periodically to determine whether the identified risks have been reduced to acceptable levels.

## 10.5 Risk Acceptance and Approval

Any residual risks remaining after implementation of security controls will be evaluated against the organization’s risk acceptance criteria.

Risk owners will review the remaining risks and provide appropriate acceptance or request additional treatment where necessary.

The Risk Treatment Plan and the residual risks accepted will be approved by the appropriate management authority.

# Statement of Applicability (SoA)

## 11.1 Introduction

The purpose of the Statement of Applicability (SoA) is to identify and describe the information security controls that Averix Technologies Pvt. Ltd. intends to apply in order to manage the information security risks identified as being relevant to its business.

Averix Technologies Pvt. Ltd. will utilize the Annex A of ISO/IEC 27001:2022 to identify the security controls required to address the identified information security risks of the organization.

The SoA will contain for each control the information as to whether the control is applicable, why the control was selected or not selected, and the implementation status of the selected controls.

## 11.2 ISO 27001:2022 Annex A Control Categories

The information security controls in ISO/IEC 27001:2022 Annex A are categorized into 4 categories with a total of 93 controls.

| Control Category | Control Count |
|---|---|
| Organizational Controls | 37 |
| People Controls | 8 |
| Physical Controls | 14 |
| Technological Controls | 34 |
| **Total** | 93 |

## 11.3 Control Applicability Assessment

All Annex A controls will be assessed for the applicability to Averix Technologies.

The assessment will consider:

1. Identified information security risks.
2. Risk treatment decisions.
3. Business and operational requirements.
4. Applicable legal, regulatory and contractual requirements.
5. The organization's technology environment and ISMS scope.

Controls are included in the SoA where they are required to address relevant information security requirements and risks.

For any control that is determined to be Not Applicable, the rationale for why the control is Not Applicable to the organization's ISMS must be documented in the SoA.

## 11.4 SoA Documentation Requirements

The following information shall be recorded for each of the Annex A controls:

1. Control reference and control name.
2. Applicability decision (Applicable or Not Applicable).
3. Justification for inclusion or exclusion.
4. Implementation status.
5. Supporting evidence or related documentation, where available.

## 11.5 SoA Review and Maintenance

The Statement of Applicability will be reviewed as required, and also whenever there is a change to the company's business operations, information security risks, technology or other requirements.

Changes to control applicability and implementation status will be documented in order to maintain an up-to-date control assessment register.

# NIST Cybersecurity Framework 2.0 Assessment

## 12.1 Introduction

The NIST Cybersecurity Framework (CSF) 2.0 provides guidance for organizations to understand, assess and manage cybersecurity risks.

The assessment will be based on the NIST CSF 2.0 and will assess the organization's cybersecurity risk management practices and help identify areas for improvement.

The framework consists of six core functions: Govern, Identify, Protect, Detect, Respond and Recover.

These functions will be used to organize cybersecurity activities and evaluate the organization's ability to manage potential security threats affecting its SaaS-based Human Resource Management System (HRMS).

### 12.2 NIST CSF 2.0 Core Functions

The following six functions shall be used to assess the organization's cybersecurity practices:

1. **Govern (GV)**
   The organization establishes and maintains an effective cybersecurity governance structure, with policies, responsibilities, risk management strategies and oversight to guide cybersecurity activities.

2. **Identify (ID)**
   Identify and understand organizational assets, information systems, vulnerabilities and cybersecurity risks.

3. **Protect (PR)**
   The organization will put in place safeguards to protect information, systems and business operations from cybersecurity threats.

4. **Detect (DE)**
   Monitoring activities and processes to identify potential cybersecurity incidents and/or suspicious activities.

5. **Respond (RS)**
   Procedures to manage cybersecurity incidents and limit their impact, with coordination of response activities as required.

6. **Recover (RC)**
   Develop recovery procedures to restore affected systems, information and business operations following cybersecurity incidents.

## 12.3 Cybersecurity Assessment Approach

The assessment of the organization’s cybersecurity practices shall be conducted based on the six functions of the NIST Cybersecurity Framework (CSF) 2.0.

This will include a review of the organization’s information security practices, the cybersecurity risks identified, the proposed security controls, and the relevant business requirements.

The assessment will focus on identifying the gaps between the organization’s current cybersecurity practices and the desired security outcomes.

## 12.4 Current and Target Cybersecurity Profiles

A Current Profile lists the cybersecurity outcomes currently being achieved by the organization.

The Target Profile describes the cybersecurity outcomes that the organization wishes to achieve, taking into account the business requirements, the risk exposure and the security priorities.

The differences between the two profiles will highlight the gaps between the organization’s current cybersecurity practices and those that are required to meet its business objectives.

The identified gaps will be considered when developing security recommendations and prioritizing improvements to the organization's cybersecurity practices.

# ISO 27001 and NIST CSF 2.0 Cross-Mapping

## 13.1 Purpose of Cross-Mapping

This section explains the cross-mapping between the information security controls in ISO/IEC 27001:2022 and the cybersecurity outcomes defined by NIST CSF 2.0.

For Averix Technologies Pvt. Ltd. this mapping will help to show how proposed ISMS controls support the identification, protection, detection, response, and recovery of cybersecurity risks for HRMS SaaS platform.

The mapping was created using the risks and systems that were identified in the existing cybersecurity risk assessment for Averix Technologies Pvt. Ltd.

## 13.2 Selected Cross-Mappings

| Security Area | ISO/IEC 27001:2022 Annex A Controls | NIST CSF 2.0 Function / Category | Application at Averix |
|---|---|---|---|
| Information security policies | 5.1 Policies for information security | Govern (GV) – GV.PO | Establish and maintain information security policies for the HRMS environment. |
| Roles and responsibilities | 5.2 Information security roles and responsibilities | Govern (GV) – GV.RR | Define accountability for management, IT, security, and HR personnel. |
| Asset management | 5.9 Inventory of information and other associated assets | Identify (ID) – ID.AM | Maintain an inventory of HRMS applications, databases, accounts, and supporting systems. |
| Access control | 5.15 Access control; 5.16 Identity management; 5.18 Access rights | Protect (PR) – PR.AT | Restrict access to employee records, payroll information, and administrative functions. |
| Security awareness | 6.3 Information security awareness, education and training | Protect (PR) – PR.AT | Train employees to identify phishing attempts and follow secure information-handling practices. |

| | | | |
|---|---|---|---|
| Vulnerability management | 8.8 Management of technical vulnerabilities | Identify (ID) – ID.RA | Identify, assess, and address vulnerabilities |
| Source code protection | 8.4 Access to source code | Protect (PR) – PR.AA | Restrict repository access to authorized developers and personnel. |
| Backup management | 8.13 Information backup | Protect (PR) – PR.DS | Protect and test backups of important HRMS data and supporting information. |
| Security logging and monitoring | 8.15 Logging; 8.16 Monitoring activities | Detect (DE) – DE.CM | Monitor system activity and identify suspicious access or abnormal behavior. |
| Incident management | 5.24 Information security incident management planning and preparation; 5.26 Response to information security incidents | Respond (RS) – RS.MA | Establish procedures to manage and respond to phishing, unauthorized access, and malware incidents. |
| Business continuity and recovery | 5.29 Information security during disruption; 5.30 ICT readiness for business continuity | Recover (RC) – RC.RP | Support restoration of HRMS services and information following a disruptive incident. |
| Supplier security | 5.19 Information security in supplier relationships; 5.20 Addressing information security within supplier agreements | Govern (GV) – GV.SC | Address security responsibilities and risks associated with cloud and other service providers. |

## 13.3 Use of Cross-Mapping in the ISMS

The cross-mapping supports the ISMS in the following ways:

1. **Control alignment:** Connects selected ISO 27001 Annex A controls with relevant NIST CSF 2.0 cybersecurity outcomes.
2. **Risk treatment:** Helps identify how proposed security controls address risks recorded in the Averix risk register.
3. **Control monitoring:** This mapping can be used to monitor the effectiveness of the security activities of the organization in achieving the desired cybersecurity outcomes.
4. **Management reporting**: Helps communicate information security activities using two recognized frameworks.
5. **Continual improvement:** Supports the identification of areas where additional security measures or improvements may be required.

## 13.4 Mapping Limitations and Considerations

This mapping is merely indicative of how the two frameworks may be used together in a portfolio project of this nature and is not to be used as a tool for establishing ISO 27001 compliance, NIST CSF conformity or for seeking certification.

As noted above, the mapping does not establish ISO 27001 compliance, NIST CSF conformity or certification of the ISMS. The control mapping must be reviewed against the organization's risk assessment, risk treatment decisions and the Statement of Applicability for the ISMS.

The cross-mapping should be verified by the organization prior to adoption of any of the cross-mappings to the framework.

# ISMS Implementation Roadmap and Action Plan

## 14.1 Purpose

The ISMS implementation roadmap defines the major activities required to establish, operate, monitor, and continually improve the Information Security Management System at Averix Technologies Pvt. Ltd.

The road map is based on the business context, ISMS scope, risk assessment, risk treatment plan, Statement of Applicability and framework cross-mapping as developed in this project.

## 14.2 Implementation Phases

| Phase | Key Activities | Expected Deliverables |
|---|---|---|
| Phase 1 – Planning and Approval | Obtain management approval, confirm ISMS scope, identify stakeholders, and assign responsibilities. | Approved ISMS scope, roles and responsibilities, project approval. |
| Phase 2 – Risk Assessment | Identify information assets, threats, vulnerabilities, assess risks, and identify risk owners. | Updated asset inventory, risk assessment, risk register. |
| Phase 3 – Risk Treatment | Select risk treatment options, determine security controls, and document control applicability. | Risk treatment plan, Statement of Applicability, risk acceptance records. |
| Phase 4 – Policy and Control Development | Develop information security policies, access control procedures, backup procedures, incident response procedures, and awareness activities. | Approved policies, procedures, and control documentation. |
| Phase 5 – Control Implementation | Implement approved security measures such as MFA, role-based access control, logging, backup protection, and vulnerability management. | Implementation records and supporting evidence. |
| Phase 6 – Monitoring and Evaluation | Monitor security controls, review incidents, conduct internal audits, and evaluate ISMS performance. | Monitoring records, audit findings, performance evaluation results. |
| Phase 7 – Improvement | Address nonconformities, implement corrective actions, review risks, and improve the ISMS. | Corrective action records and improvement plan. |

## 14.3 Proposed Action Plan

| Action ID | Action | Responsible Role | Priority | Target Timeline |
|---|---|---|---|---|
| AP01 | Obtain management approval for the ISMS scope and policy. | Top Management | High | Month 1 |
| AP02 | Review the asset inventory and assign asset owner | IT Manager | High | Month 1 |
| AP03 | Review user permissions and implement role-based access control. | System Administrator | High | Months 1–2 |
| AP04 | Enable multi-factor authentication for critical accounts. | IT Manager | High | Months 1–2 |
| AP05 | Establish backup verification and restoration testing. | System Administrator | High | Months 2–3 |
| AP06 | Conduct employee information security awareness training. | GRC Analyst / HR Manager | Medium | Month 2 |
| AP07 | Establish security logging and monitoring procedures. | IT Manager | High | Months 2–3 |
| AP08 | Document and test the incident response procedure. | GRC Analyst / IT Manager | High | Months 3–4 |
| AP09 | Review supplier security responsibilities and agreements. | Top Management / IT Manager | Medium | Months 3–4 |
| AP10 | Conduct an internal ISMS audit and management review. | Internal Auditor / Top Management | High | Months 5–6 |

## 14.4 Monitoring of Implementation Progress

Implementation progress can be monitored by means of periodic reviews and evidence documentation.

The following indicators can be used:

1. Percentage of identified information assets with assigned owners.
2. Percentage of critical accounts protected by multi-factor authentication.
3. Percentage of scheduled backup restoration tests completed successfully.
4. Number of employees completing information security awareness training.
5. Number of unresolved high and critical information security risks.
6. Number of security incidents recorded and reviewed.
7. Percentage of planned corrective actions completed.

The responsible roles should maintain implementation records and report significant delays, control failures, unresolved risks to management.

## 14.5 Review and Continual Improvement

The implementation roadmap should be reviewed periodically to ensure that planned activities remain aligned with business requirements and the changing threat environment.

Changes to the HRMS application, supporting infrastructure, business processes, suppliers or applicable requirements should trigger a review of relevant information security risks and controls.

Internal audit findings, security incidents, monitoring results and management review decisions should be used to identify improvement opportunities.

Corrective actions should be assigned to responsible personnel, tracked to completion and reviewed for effectiveness.

## 14.6 Implementation Status and Project Limitations

This roadmap represents a proposed implementation plan prepared for a fictional portfolio project. The timelines, priorities, responsible roles, expected deliverables are planning assumptions.

No actual implementation, internal audit, management review or independent verification is claimed. Evidence of implementation and control effectiveness would be required before reporting the ISMS as operational or making claims of conformity or certification.

# ISMS Monitoring and Internal Audit

## 15.1 Purpose

The monitoring and internal audit of the Information Security Management System (ISMS) of Averix Technologies Pvt. Ltd. is designed to verify that the ISMS is functioning correctly.

The monitoring and internal audit activities help Averix Technologies Pvt. Ltd. to identify security incidents, control weaknesses and improvements.

## 15.2 ISMS Monitoring

Averix plans to monitor the following security activities:

| Area | What will be checked |
|---|---|
| User Access | Whether only authorized users can access HRMS data. |
| Backups | Whether important data is backed up regularly. |
| Security Incidents | Whether security incidents are reported and recorded. |
| Employee Awareness | Whether employees receive security training. |
| System Updates | Whether systems receive required security updates. |
| Risk Management | Whether identified security risks are reviewed. |

## 15.3 Internal Audit

An internal audit shall be conducted to verify that the Information Security Management System (ISMS) conforms to the planned security policies of Averix Technologies Pvt. Ltd. as well as to the requirements of the ISO 27001 standard.

The audit will include:

1. Reviewing information security policies and procedures.
2. Checking access control and user permissions.
3. Reviewing backup and recovery records.
4. Checking security incident records.
5. Reviewing risk assessment and treatment documents.
6. Identifying gaps and nonconformities.

## 15.4 Audit Responsibilities

| Role | Responsibility |
|---|---|
| Top Management | Review audit results and support improvements. |
| GRC Analyst | Coordinate audit activities and maintain records. |
| IT Team | Provide technical information and supporting evidence. |
| Internal Auditor | Conduct the audit and report findings. |

The internal auditor shall be objective and independent of the activities being audited.

## 15.5 Audit Findings and Corrective Actions

Any identified problem should be recorded and assigned to a responsible person.

The organization should:

1. Record the audit finding.
2. Identify the reason for the problem.
3. Decide the corrective action.
4. Assign responsibility and a target date.
5. Check whether the action has been completed effectively.

## 15.6 Project Note

This page outlines the proposed monitoring and internal audit for the fictional Averix organization. No internal audit or control testing has been conducted for this portfolio project.

# Management Review and Continual Improvement

## 16.1 Purpose

The purpose of management review is to determine the suitability and effectiveness of Averix Technologies Pvt. Ltd.'s Information Security Management System (ISMS).

It also enables management to identify issues related to security and make decisions regarding improvements that need to be made.

## 16.2 Management Review Activities

Management will periodically review:

1. Results of internal audits.
2. Information security risks and their treatment status.
3. Security incidents and reported problems.
4. Progress of planned security activities.
5. Feedback from employees and customers.
6. Opportunities to improve information security.

## 16.3 Roles and Responsibilities

| Roles | Responsibility |
|---|---|
| Top Management | Review ISMS performance and approve important decisions. |
| GRC Analyst | Prepare review documents and report security issues. |
| IT Manager | Provide updates on technical security controls. |
| HR Manager | Provide updates on employee awareness and training. |

## 16.4 Management Review Outputs

After the review, management may decide to:

1. Update information security policies.
2. Improve existing security controls.
3. Provide additional employee training.
4. Address unresolved security risks.
5. Assign corrective actions.
6. Provide resources for security improvements.

The decisions made during management review shall be documented and assigned to the relevant person(s).

## 16.5 Continual Improvement

Monitoring, internal audits, risk reviews, incident investigations and corrective actions shall be used to improve the ISMS of Averix.

Example: If weak user access controls are identified during an audit, management may decide to implement stronger access controls and conduct regular permission reviews.

The organization should check whether these improvements are effective.

***Note:*** *The management review and continual improvement process proposed in this document is for the fictitious organization Averix. No management review or improvement activity was performed for this portfolio project.*

# Conclusion

The project outlined in this document is a proposed Information Security Management System (ISMS) for Averix Technologies Pvt. Ltd.'s HR Management Software as a Service (SaaS) environment.

The current cybersecurity risk assessment is used as the basis of the proposed ISMS and the key elements of the ISO/IEC 27001:2022 and the NIST Cybersecurity Framework 2.0 have been included.

The project covered:

1. Understanding the organization's business context.
2. Identifying interested parties and their requirements.
3. Defining the ISMS scope.
4. Establishing information security roles and responsibilities.
5. Assessing and treating information security risks.
6. Preparing a Statement of Applicability.
7. Mapping selected security controls to NIST CSF 2.0.
8. Developing an implementation plan.
9. Planning monitoring, internal audits, and management reviews.

This project outlines how organizations can plan and structure an Information Security Management System (ISMS) to protect sensitive employee information, payroll records, user accounts, and supporting HRMS systems.

***Project Disclaimer:*** *Averix Technologies Pvt. Ltd. is a fictional organization created for educational and portfolio purposes. This document represents a proposed ISMS design and does not claim actual implementation, independent audit, ISO 27001 certification, or verified compliance with any framework.*